

[“]Assessment tool :- 3 [CO2][”]

Name :- P. Reddy Swetha

Reg No :- 192311206

Department :- CSE

Course :- Ethical Hacking

Code :- ITA1408

Topic 1:- Footprinting Tools - Conducting Competitive Intelligence.

Footprinting is the process of gathering information about a target organization. In passive footprinting information is collected from public sources without directly scanning or attacking the company's servers.

For ABC Technologies, the following tools can be used:-

1) Domain Registration Details - WHOIS

WHOIS provides information about the company's registered domain.

It can reveal:

- Domain register
- Name Servers
- Registration and expiry data
- Domain status
- Organization details, if publicly available.

Competitive Intelligence:- Helps understand the company's domain infrastructure, DNS provider, domain history.

Ex:- Whois abctechnologies.com

2) Employee Email Addresses - theHarvester

The Harvester is an OSINT tool used to collect publicly available information from supported search and public-data sources.

It can identify:

- Public employee email addresses
- Employee names
- Email naming patterns
- Public hosts and subdomains

Competitive Intelligence:- Helps understand the company's

Public employee contact structure and identify information that could be exposed to phishing risks.

Ex:- theHarvester -d abctechnologies.com -b bing

3) Technology Stack - Builtwith / Wappalizer

Builtwith and Wappalizer identify technologies associated with websites.

They may identify:

- web server - Apache / Nginx
- CMS - Wordpress
- Framework - React / Angular
- CDN - CloudFlare
- Analytics services

Competitive Intelligence:- Helps compare the technologies used by ABC Technologies with competitors and identify potentially outdated technologies.

4) Public subdomains - crt.sh

crt.sh searches public Certificate Transparency records to find hostnames associated with a domain.

Possible subdomains:

- www.abctechnologies.com
- mail.abc~~technologies~~.com
- api.abctechnologies.com
- portal.abc~~technologies~~.com

Competitive Intelligence:- Helps understand the company's public facing infrastructure and identify services such as APIs, portals, mail systems and development environments.

topic 2 :- DNS Zone Transfer - Authorized Penetration

testing:

A DNS Zone transfer is a process where DNS records are copied from one DNS server to another. If a DNS server is misconfigured, an unauthorized user may be able to retrieve the complete DNS Zone information.

1) Find the DNS Name Server :-

Use Nslookup or dig to identify the target's authoritative name servers.

Ex:- nslookup -type=ns example.com (or)

dig NS example.com

result:- ns1.example.com

ns2.example.com

2) Test the Zone Transfer :- use the dig command

with AXFR: dig AXFR example.com @ns1.example.com

Here :- → AXFR: Requests a complete DNS Zone transfer

→ example.com : Target domain

→ @ns1.example.com : DNS server being tested

If the server is properly configured, the request should be refused or fail.

→ If it is misconfigured, DNS records may be returned.

3) Information Obtained :-

A successful transfer can expose records such as:

Record

A/AAAA

MX

Information

Hostnames and their IP addresses

Mail servers.

NS
CNAME
TXT

DNS/name servers
Aliases and related services
Public configuration / verification
information.

For example:

mail.example.com	A	192.0.2.10
portal.example.com	A	192.0.2.20
example.com	MX	mail.example.com
dev.example.com	CNAME	server.example.com

4) Use in Reconnaissance:

The retrieved information helps the authorized tester identify:

- Internal / related hosts: Hostnames and IP addresses can reveal network structure.
- Mail Servers: MX records identify system responsible for email.
- Subdomains: Names such as dev.example.com, vpn.example.com and portal.example.com services.
- DNS infrastructure: NS records identify authoritative Domain Name System servers

Conclusion:

During an authorized penetration test, dig AXFR can be used to check whether a DNS server incorrectly permits Zone transfer. A successful transfer can reveal hosts, IP addresses, mail servers, name servers and subdomains, giving the tester a detailed view of the target's DNS infrastructure.

Topic 3: Social Engineering Attacks and Countermeasures

Social Engineering is an attack technique where attackers manipulate people into revealing confidential information such as usernames, passwords, OTPs.

In this scenario, employees receive a fake email pretending to be from the IT department and asking them to verify their login credentials using a link.

1. Type of Attack - Phishing

This is a phishing attack.

Phishing occurs when an attacker sends a fraudulent email or message that appears to come from a trusted source and tries to make the victim reveal information.

→ The attacker uses two important techniques here

Impersonation: Pretends to be the IT department

Urgency: uses an urgent security update to pressure employees into acting quickly.

The link may lead to a fake login page designed to steal usernames and passwords.

2. Countermeasures Employees Should Follow:

A. Do Not click the link immediately:

Employees should avoid clicking links in unexpected or suspicious emails.

Benefit: Prevents users from being redirected to a fake login website.

B. Verify the sender :-

Check the Complete Sender email address.

Ex: Real : Support@Company.com

Fake : Support - Company@gmail.com

C. Verify with the IT Department:

Contact the IT department using an official phone number, help desk or internal communication channel, rather than replying to the suspicious email.

Benefit: Confirms whether the security update is genuine.

D. Check the Link Carefully:

Hover over the link without clicking it and check its destination. Employees should be careful about misspelled or unrelated domains.

Expected: login.company.com

Suspicious: Company-login-security-example.

Benefit: Helps identify links leading to fake websites.

E. Never Share Passwords or OTPs

Employees should never provide passwords, OTPs, recovery codes, or other sensitive authentication information through an email request.

Benefit: Directly reduces the chance of credential theft.

F. Enable Multi-factor Authentication (MFA)

MFA requires an additional verification factor beyond the password.

Password + second authentication = Account access.

G. Security Awareness:

Organizations should regularly train employees to

recognize: → Fake login pages, Suspicious links.

→ Sender impersonation

→ Urgent requests for credentials.